

Intrusion Detection Systems (IDS)

M1 (RSI)

Computer Security (S1)

Chapter 1: Basic Concepts

Chapter 2: Malwares (Types, History, Analysis)

Chapter 3: Network Threats (DDoS, TCP Session Hijacking, MITM, etc.)

Chapter 4: Web Threats (SQL Injection, etc.)

Context

- Last semester, you learned to analyze network logs to detect a keylogger. (Details ?)
- Imagine analyzing a 100 MB PCAP file containing one hour of network traffic.
- How long will it take you?

Scaling Problem

- Now imagine analyzing logs from 100 machines over 24 hours.
- This represents terabytes of data.
- Manual analysis becomes impossible.
- How can you ensure nothing is missed?

The Attack Becomes More Sophisticated

- The attacker encrypts their traffic  → Keystrokes are no longer visible.
- They use a hidden tunnel  → Data is exfiltrated unnoticed.
- Malware other than keyloggers? Viruses, for example, **which logs ?**
 - **Are Network Logs Enough!**

Network Logs Are Not Enough!

Other types of logs must be analyzed:

- System logs (suspicious logins, critical file changes).
- Application logs (abnormal database or web server activity).
- Windows/Linux event logs (privilege escalation, unauthorized access).

Solution: Intrusion Detection Systems (IDS)

- An IDS allows:
 - ✓ Real-time log analysis.
 - ✓ Detection of hidden anomalies and attacks.
 - ✓ Automatic alert generation.

Red or Blue Team Competences ?

Unité d'Enseignement	VHS	V.H hebdomadaire (0h 30= 30 minutes)				Coeff	Crédits	Mode d'évaluation	
	14-15 sem	C	TD	TP	Travail personnel			Continu	Examen
UE fondamentales	18 crédits								
UEF1 (O/P)									
Politiques de sécurité	45H	1h30		1h30	3 h	2	4	50%	50%
UEF2 (O/P)									
Administration des réseaux	45h	1h30		1h30	3 h	2	4	50%	50%
UEF3(O/P)									
Systèmes biométriques	45h	1h30		1h30	5 h	2	5	50%	50%
UEF4(O/P)									
Programmation orientée objet appliquée aux réseaux	67h30	1h30	1h30	1h30	3h	2	5	50%	50%
UE méthodologie	9 crédits								
UEM 1 (O/P)									
Recherche bibliographique	22h30	1h30				1	1	60%	40%
UEM 2 (O/P)									
Théorie des graphes avancée et applications	45	1h30	1h30		3h	4	4	60%	40%
UEM 3 (O/P)									
Les systèmes de détection d'intrusion	45	1h 30		1h 30	3h	4	4	50%	50%
UE Transversale	3 crédits								
UET1 (O/P)									
Législation	22h30	1h 30			1h30	1	1	60%	40%
UE Découverte									
UED2 (O/P)									
Les grilles de calcul Vs Cloud	22h30	1h30				1	1	60%	40%

Syllabus

1. Title: Intrusion Detection

2. Teaching Unit: UEM3

3. Credits: 4 **Coefficient:** 4

4. Total Weekly Hours: 3h

- **Lecture** (hours per week): 1h30
- **Practical Work** (hours per week): 1h30

5. Assessment Method:

- **Presentation/Practical Work:** 50%
- **Exam:** 50%

Syllabus

Chapter 1: Basic Concepts (Terminology, Architecture, Detection Methods, etc.)

Chapter 2: Host-Based IDS (File Integrity Monitoring) **vs.**
Network-Based IDS (Snort)

Chapter 3: AI-Based IDS

Prerequisites

- Basic knowledge of Computer Security

Course objectives

- Understand key concepts of intrusion detection, including architecture and methods.
- Compare host-based and network-based IDS in terms of functionality and use cases.
- Use SIEM tools (e.g., Splunk) for threat detection and log analysis.
- Apply AI techniques to enhance intrusion detection and anomaly detection.

Computer Security, IDSs, and Research Projects (Master's and PhD) ?

What is an intrusion?

- ✓ Any action aimed at compromising a computer system (machine, operating system, network) and its security objectives.
- ✓ This action can:
 - succeed, fail, be in progress, or simply be a preparatory phase.

What is intrusion detection?

- ✓ It means looking at security records to find possible attacks.
- ✓ It is one part of a full security system, not a separate protection by itself.

What is an Intrusion Detection System (IDS)?

- ✓ An IDS is any tool, method, or resource that helps predict or identify unauthorized activities in a network.
- ✓ It detects events that may indicate an intrusion.

Why look for signs of intrusion if
we are protected ?

Firewalls are not enough ?
Anti-Malwares are not enough ?

Why the IDSs ?



- ❖ Firewalls control access, but they **don't detect attacks inside** the network
 - A firewall blocks unauthorized traffic, but if an attacker bypasses it the firewall won't notice.
 - An IDS monitors internal activity and can detect suspicious behavior.

Why the IDSs ?

- ❖ Antivirus software detects known threats, but not new or hidden attacks
 - Antivirus programs rely on signature-based detection, meaning they recognize known malware.
 - An IDS can identify unusual behavior, even if the attack is new.

Why the IDSs ?

- ❖ Security **misconfigurations** and human errors
 - No system is perfectly configured; there may be weak spots.
 - An IDS can catch failed login attempts, abnormal traffic, or policy violations that indicate a security risk.

Why the IDSs ?

❖ Backdoor !

Recap

- ❖ Syllabus and Chaptres
- ❖ Why look for signs of intrusion if we are protected ?
- ❖ Scalling

Uses of IDS: Various Objectives

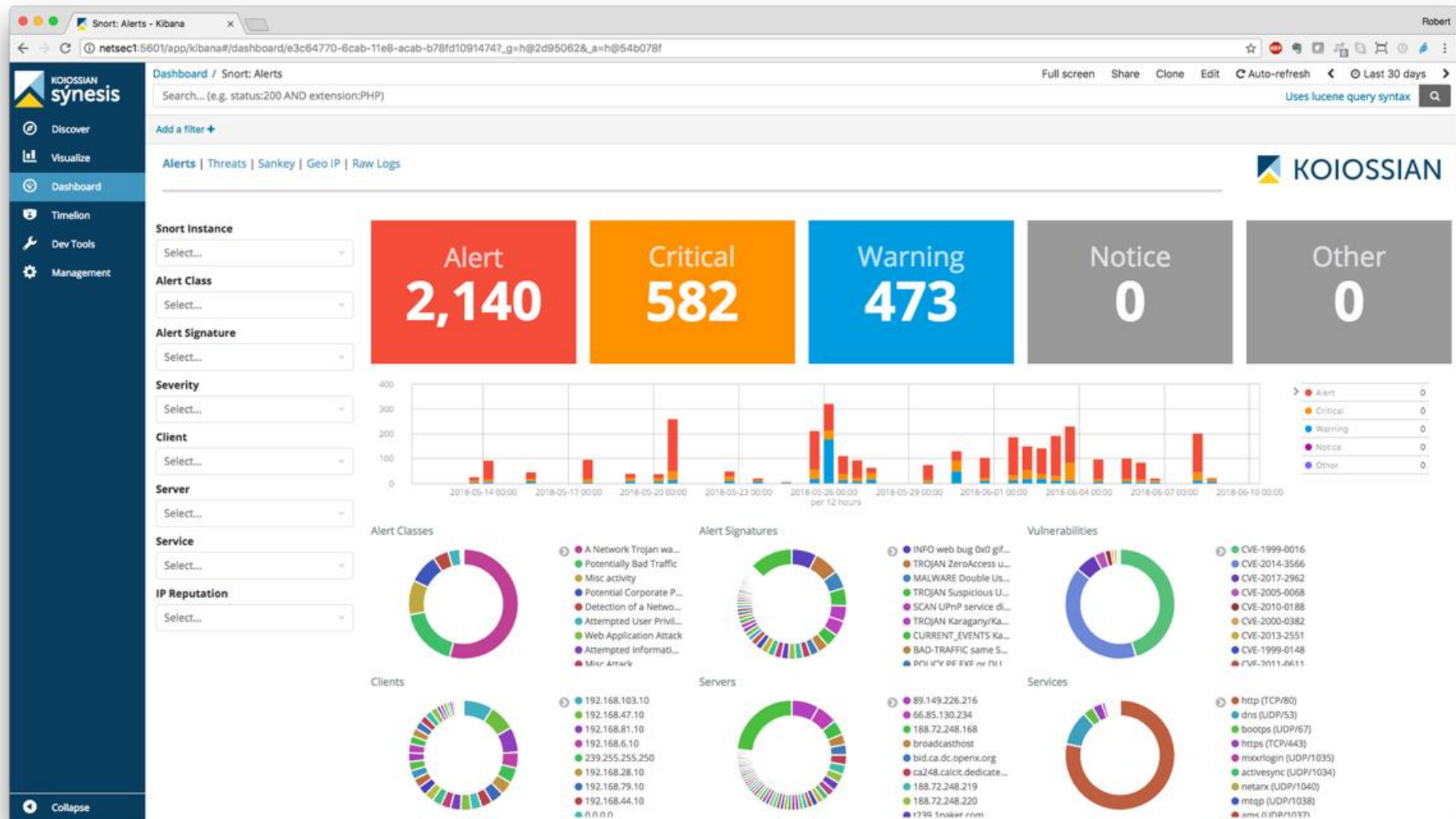
Global Role in a Security Architecture:

- ❖ Support for defenses
- ❖ Security policy control
- ❖ Prevention when its deployment is known (deterrence?)
- ❖ Facilitate the implementation of appropriate defenses
 - Detection of unknown attacks
 - Detection of preliminary attack phases

Uses of IDS: Various Objectives

Statistical Role (dashboard):

1. Source of information for the hierarchy
2. Overview of common threats



How to Detect an Intrusion?

- ❖ By **monitoring system activity** (network, Kernel, or application) to collect various events (**Audit logs**).
- ❖ By **analyzing these events** to detect suspicious signs.

IDS aim to automate these phases of information collection and analysis.

Event Collection

❖ How can i access to the audit logs file on my machine ?

Auditable System logs

According to the security policy and the desired security level, the administrator can define auditable events corresponding to certain information, which may include:

- ❖ **System access:**

Who accessed the system? When? Where? And how?

- ❖ **Use of system resources:**

Information related to the use of system resources, such as system commands, CPU, RAM, and input/output operations.

Auditable System logs

❖ File usage:

Includes all information regarding file access, such as access timestamps, type of access, source of access, etc.

❖ Application-related events:

Events generated by applications, such as application startup and shutdown, inputs used, and outputs produced, etc.

❖ Potential security violations:

Unauthorized attempts to access system resources, such as executing an application or command in privileged mode, modifying access rights, etc.

❖ System statistics:

Statistical information that can help identify any abnormal activity, such as statistics on the number of denied access attempts.

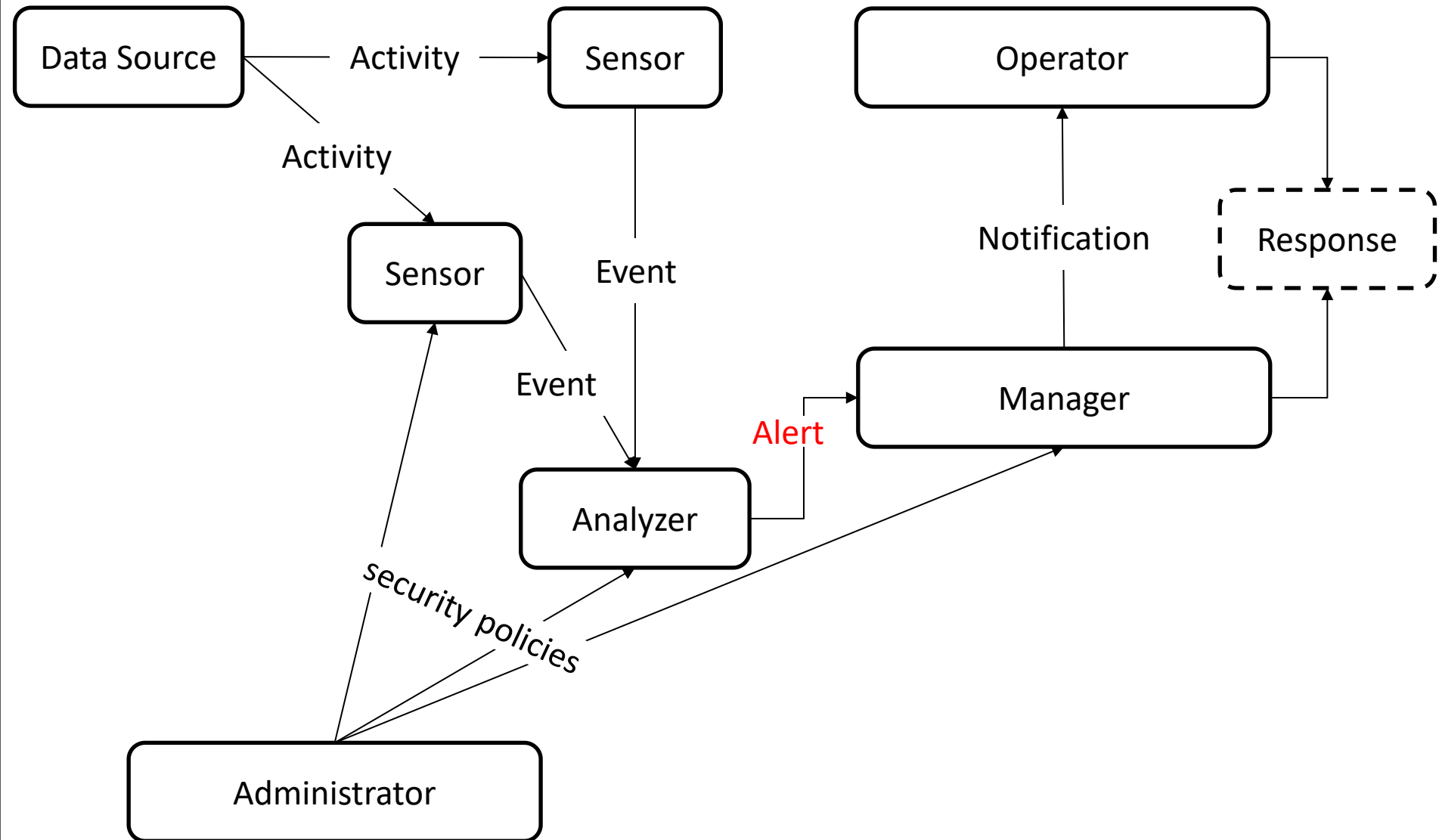
Audit log analysis

- ❖ Should the analysis of audit logs be performed in real-time or later?

Audit log analysis

- ❖ Some attacks attempt to alter audit logs, so they must be protected from unauthorized modifications, including during network transmission.

IDS Architecture Based on IDWG

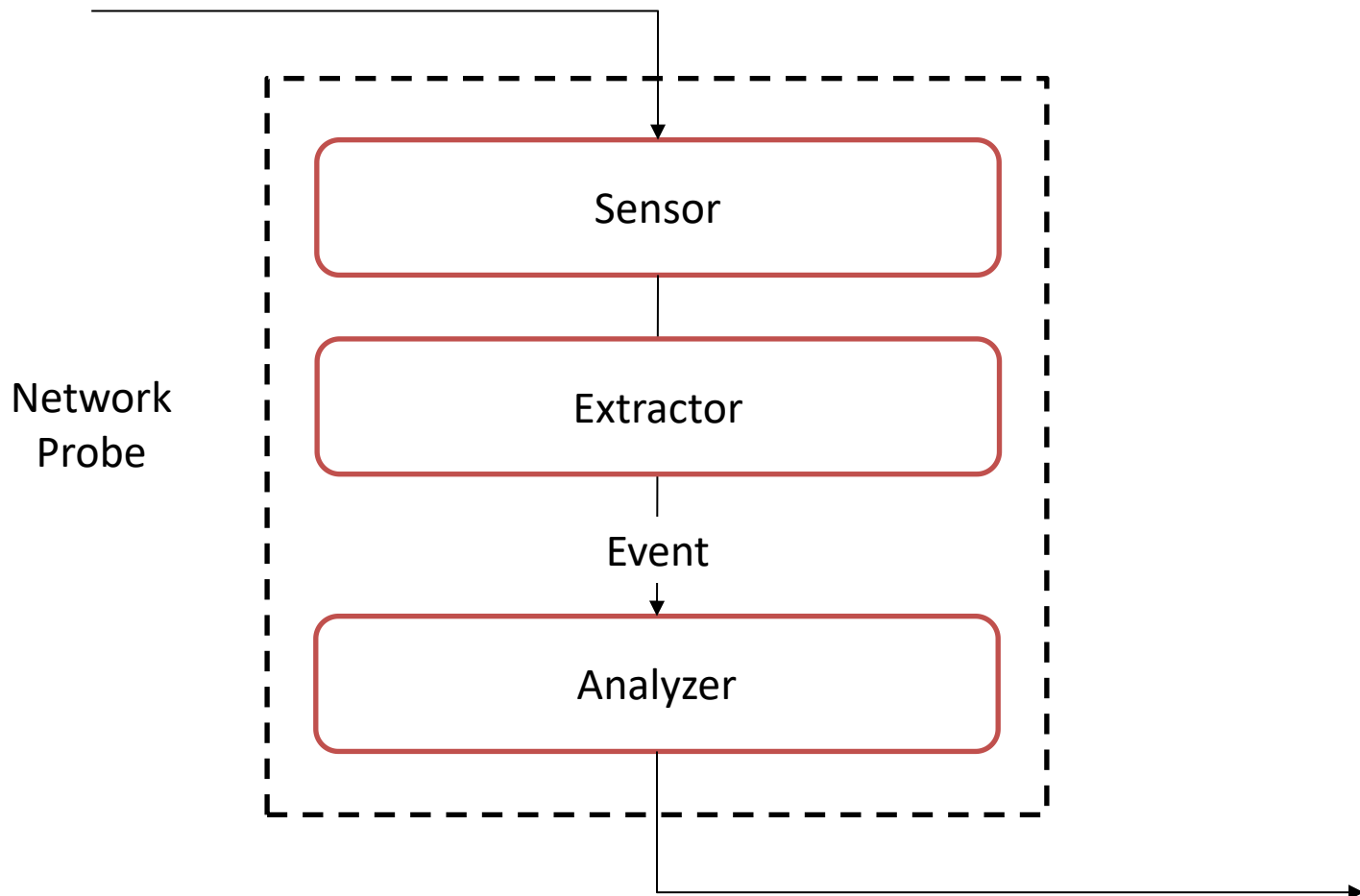


IDS Architecture Based on IDWG

- ❖ **Responses** can be carried out **automatically** by an entity within the IDS architecture **or** initiated by a **human**.
- ❖ Possible actions include:
 - Sending a notification to the operator
 - Logging the activity and Recording the data that characterized the event
 - Stopping the network, the user, or the application session

IDS Architecture Based on IDWG

❖ Network probe (sonde réseau):



IDS Architecture Based on IDWG

❖ Exemple of an IDS !

Alert and False Alert

	No Alert	Alert
No Attack	True Negative	False Positive
Attack	False Negative	True Positive

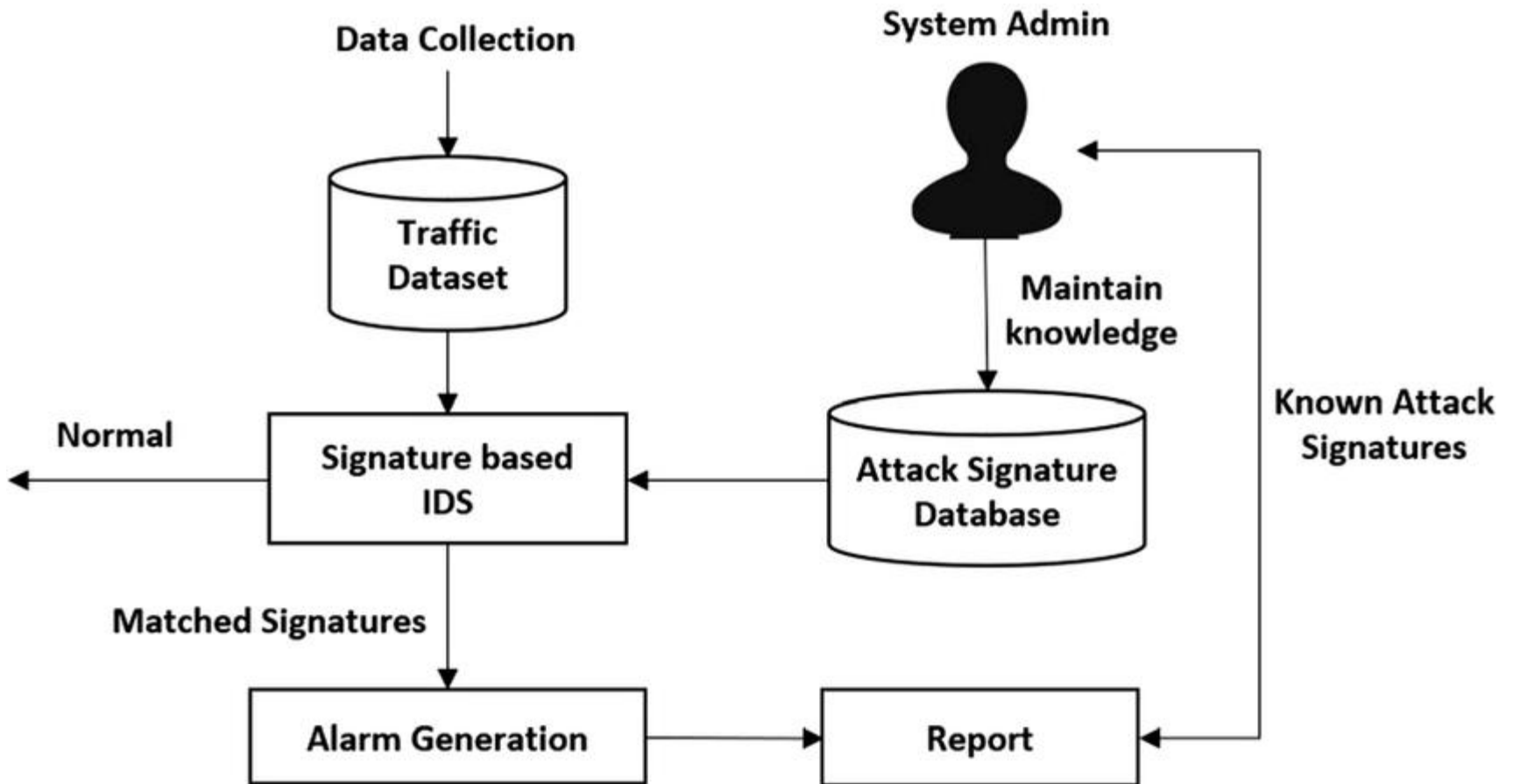
Rappel

1. How to Detect an Intrusion?
2. How can i access to the audit logs file on my machine ?
3. Auditable System logs ?
4. Activity vs Event ? Network probe (sonde réseau)?
5. FNR, FPR

Intrusion Detection Methods

1. Signature-Based Detection
2. Anomaly-Based Detection
3. Hybrid Detection (signature + anomaly)
4. IA-Based Detection

Signature-Based Detection

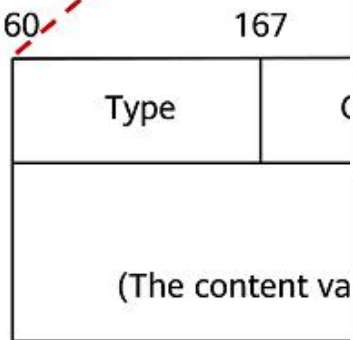
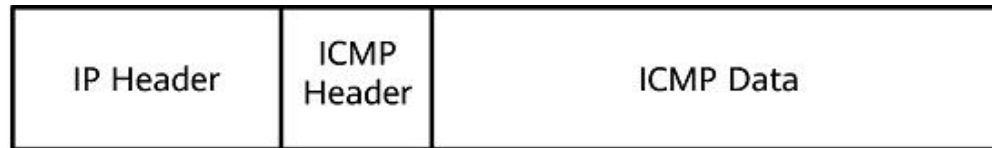


Signature-Based Detection

- ✓ **Monitors system activity** for fingerprints (signatures) of **known attacks**.
 - ✓ **Relies on a database** of intrusion signatures (rules).
 - ✓ **Scans audit logs** to identify matching patterns.
 - ✓ **Triggers an alert** if an event matches a signature from the database.
- ⚠ **Limitation:** Only **known attacks** can be detected—new or modified threats may go unnoticed.

Signature-Based Detection

Basic IDS Rule - Detecting a Ping (ICMP Echo Request):



ICMP Type	Signification
0	Echo Reply (réponse au ping)
3	Destination Unreachable (destination injoignable)
5	Redirect (redirection de route)
8	Echo Request (requête ping)
11	Time Exceeded (TTL dépassé)

Signature-Based Detection

Basic IDS Rule - Detecting a Ping (ICMP Echo Request)

```
alert icmp any any -> any any (msg:"Ping detected"; itype:8; sid:1;)
```

Signature-Based Detection

Question: Based on what you've studied, **what is the signature of a SYN Flood attack?** **What key characteristics can we use to detect it?**

Signature-Based Detection

- 1 ☐ TCP Flags
- 2 ☐ Packet Frequency and Volume
- 3 ☐ Source IP Addresses
- 4 ☐ Destination and Source Ports
- 5 ☐ Packet Size
- 6 ☐ Incomplete TCP Handshake

```
alert tcp any any -> any any (msg:"Possible SYN Flood Attack";  
flags:S; threshold:type both, track by_src, count 50, seconds 10;  
sid:1000001; rev:2;)
```

Advantages and Limitations of Signature-Based IDS

➤ Advantage:

- Quickly detects and blocks known threats using a predefined signature database, ensuring fast response times.

➤ Disadvantage:

- Vulnerable to evasion techniques and ineffective against new threats without frequent signature updates.
- While providing real-time protection, its reliance on existing signatures requires continuous maintenance to remain effective.

Anomaly-Based Intrusion Detection

Anomaly-based detection identifies intrusions by monitoring system activities and categorizing them as either **normal or anomaly**. Understanding typical behavior patterns to identify malicious activity deviations helps in spotting potential threats.

Anomaly-Based Intrusion Detection

Anomaly-based IDS operates in two phases:

1. **training** to establish a normal behavior profile and testing to compare ongoing activities against this profile.
2. **Establishing** normal behavior baselines allows these systems to detect deviations that could signal malicious activity.

Anomaly-Based Intrusion Detection

The ability to identify deviations from established baselines makes anomaly-based IDS a powerful tool for spotting new or previously unknown threats.

How Anomaly-Based IDS Works

Baselines are
Defined



1

Anomalies are
detected



3

Baselines are updated
based on the response



5

2



System goes into
learning more

4



Severity levels
are assigned

How Anomaly-Based IDS Works

1. Defining Baselines

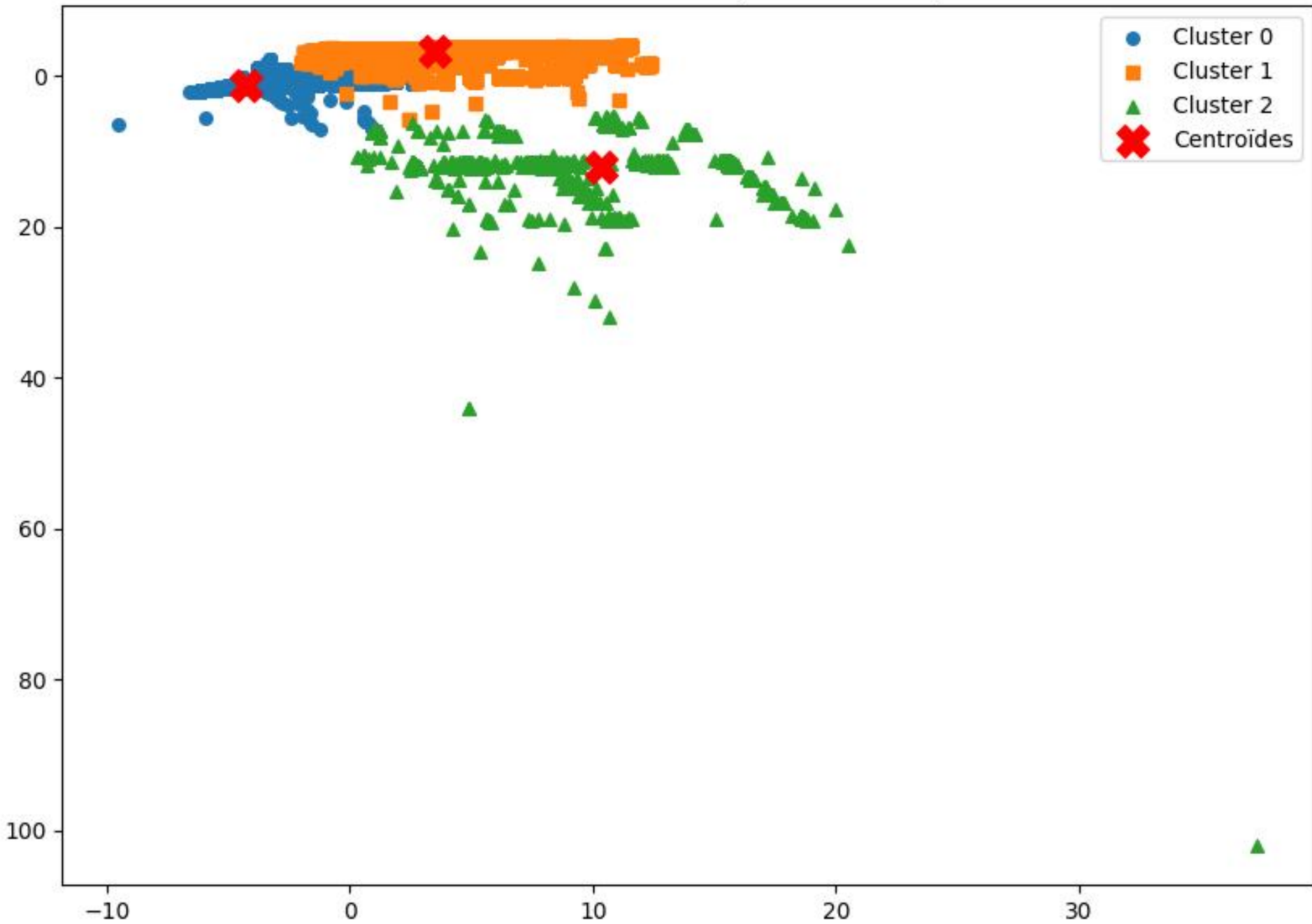
- ❖ Establish reference points for normal system behavior using historical data.
- ❖ Use statistical measures like mean and standard deviation to define normalcy.

How Anomaly-Based IDS Works

2. Learning from Data

- ❖ **Machine learning** models analyze historical data to establish and refine baselines.
- ❖ **Clustering** algorithms (e.g., K-means) group normal patterns and detect outliers.

Clusters avec K-Means (Dataset Initial)

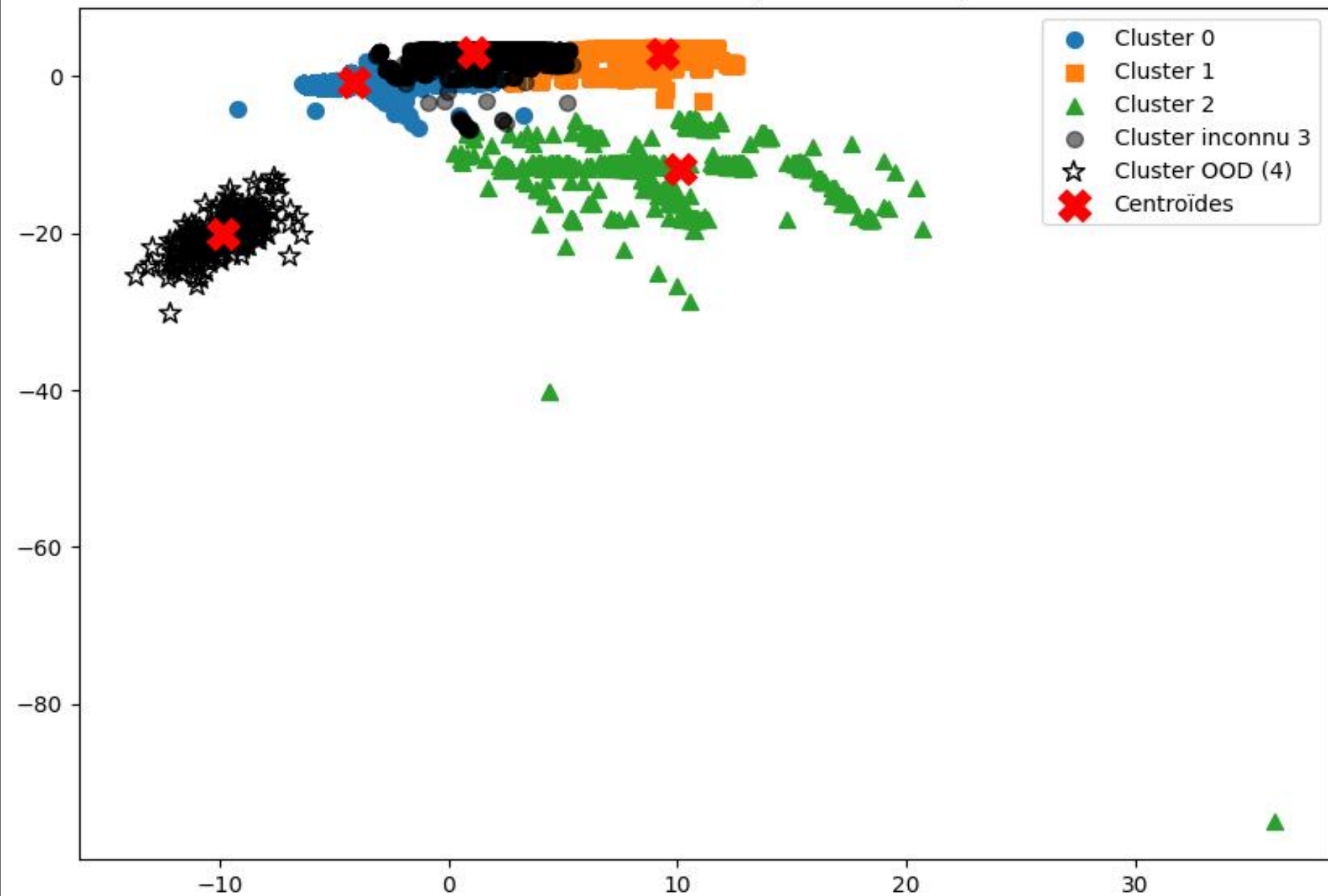


How Anomaly-Based IDS Works

3. Detecting Anomalies

- ❖ Incoming data is compared against the established baseline.
- ❖ Deviations from normal patterns are flagged as potential anomalies.

Clusters avec K-Means (Incluant OODs)

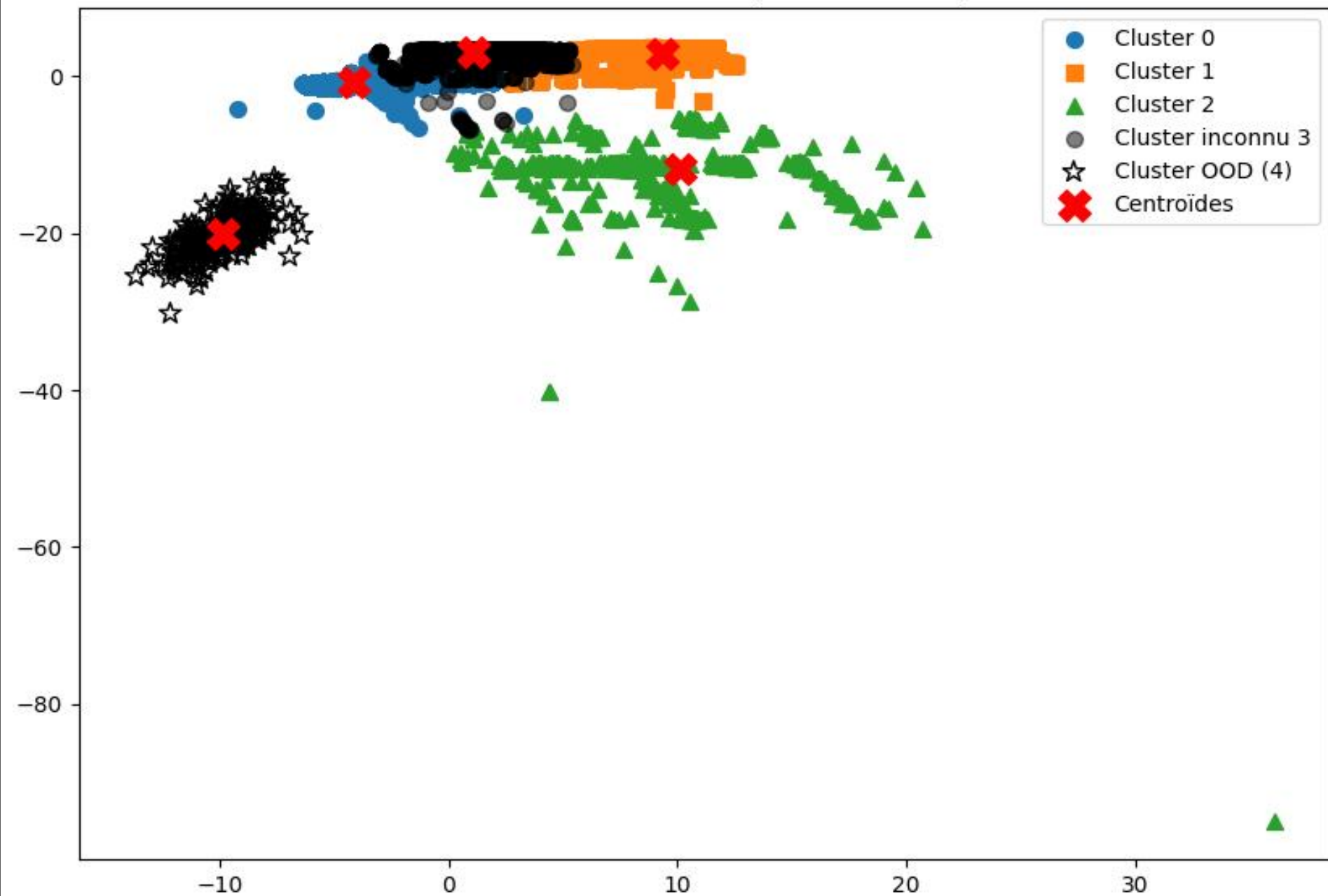


How Anomaly-Based IDS Works

4. Assigning Severity Levels

- ❖ The extent of deviation determines the severity of anomaly alerts.
- ❖ Greater deviations indicate higher risk levels.

Clusters avec K-Means (Incluant OODs)



How Anomaly-Based IDS Works

5. Updating Baselines

- ❖ Regularly refresh baselines with new data to adapt to evolving trends.
- ❖ Continuous updates ensure anomaly detection remains effective.

Advantages and Limitations of **Anomaly-Based IDS**

➤ **Advantage:**

- Detects new threats by learning normal network behavior and adapting to changes.

➤ **Disadvantage:**

- High resource consumption and increased false positives due to misclassification of legitimate activity.
- It require accurate baselines, poor baselines weaken detection.
Continuous learning helps reduce false positives and improve accuracy.

2. Signature-Based **vs.** Anomaly-Based Detection

What are the key differences between signature-based and anomaly-based intrusion detection ? (*Method, New attacks, False Positives*)

Feature	Signature-Based Detection	Anomaly-Based Detection
Detection Method	Compares traffic with known attack signatures	Detects deviations from normal behavior
Ability to Detect New Attacks	Low (requires predefined rules)	High (can detect unknown attacks)
False Positives	Low	High (due to normal behavior variations)

Hybrid Detection (Signature + Anomaly)

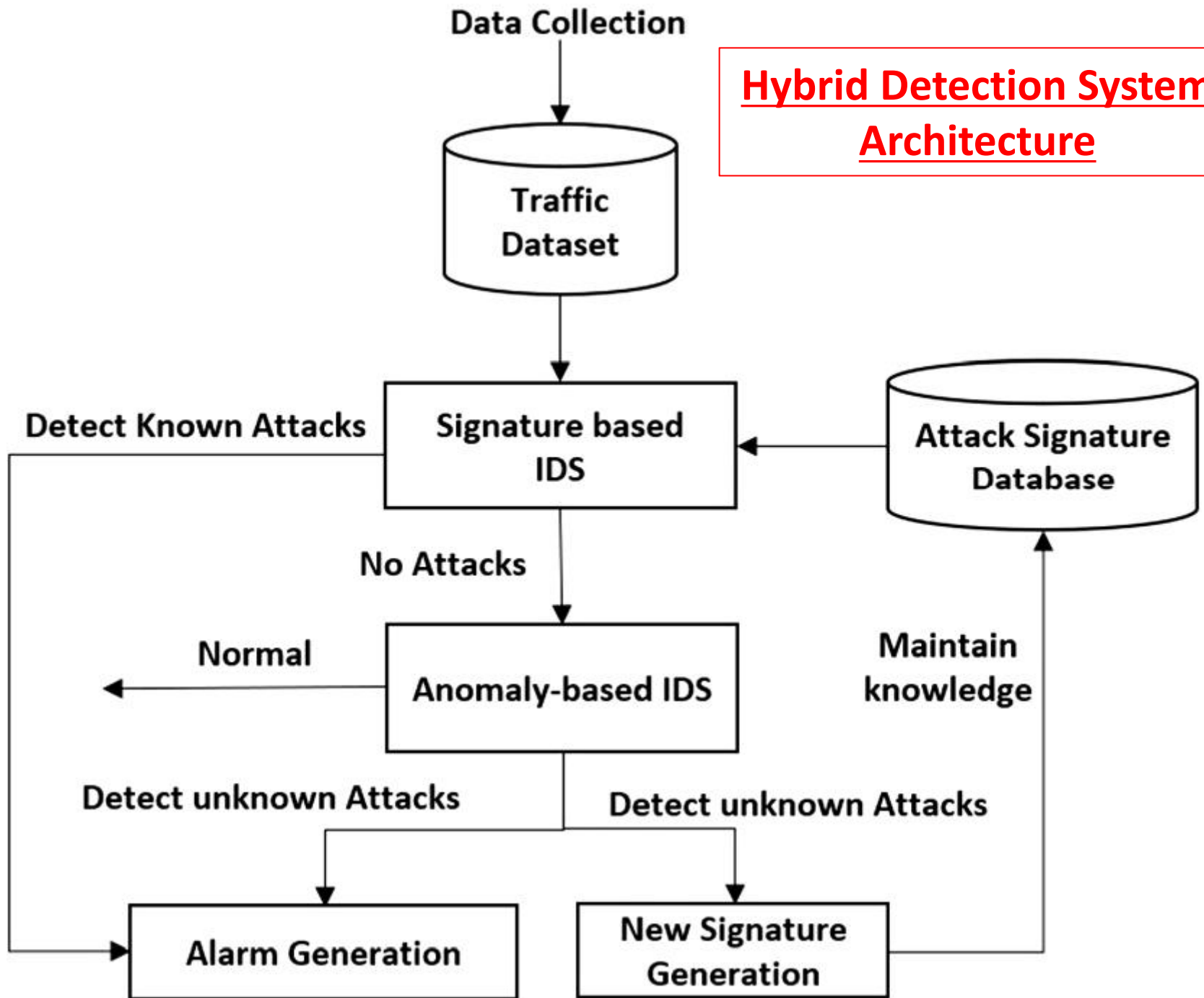
Why ?

Hybrid Intrusion Detection Systems

Hybrid intrusion detection systems integrate both anomaly-based and signature-based detection to optimize security measures.

By combining these methods, hybrid intrusion detection system can effectively **identify both known** threats through signatures **and new threats** via anomaly detection.

Hybrid Detection System Architecture



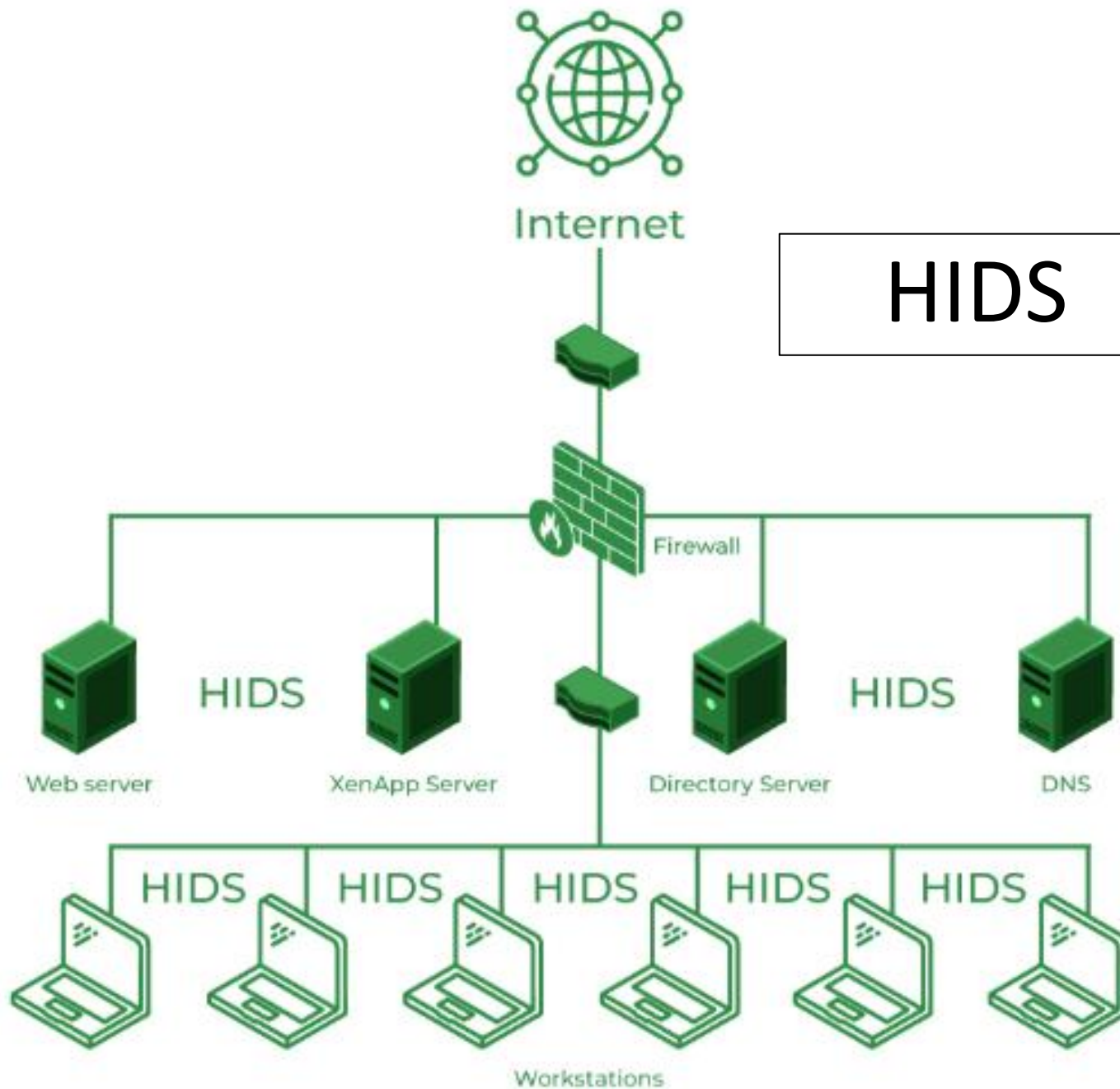
HIDS

(Host-based Intrusion Detection System)

What is HID?

This intrusion detection system takes the host as a complete world in itself.

It can be a computer (PC) or a server that can serve as a system in itself, analyzing and monitoring its internals.



HIDS

Core Functions of HIDS

1. File Integrity Monitoring (FIM)

- Function: Detects unauthorized changes to files and directories.

Example:

Malware modifying system files – A virus targets critical Windows system files (e.g., winlogon.exe) and modifies them to maintain persistence. FIM detects this unauthorized change and triggers an alert.

Why is FIM Important?

1. Prevents Persistence:

Do you remember the attack vector?

Why does it delete its traces?

- Attackers often modify system files or configurations to maintain access to a system. FIM can detect these changes early.

Why is FIM Important?

2. Compliance: Many regulatory standards (e.g., **PCI DSS, HIPAA**) require FIM to ensure data integrity.

- When you hear regulatory standards ?
- Why is 27000 necessary for companies ?

Why is FIM Important?

- PCI DSS (Payment Card Industry Data Security Standard) ensures the security of card payment transactions, protecting cardholder data from fraud and breaches.
- HIPAA (Health Insurance Portability and Accountability Act) is a U.S. regulation that safeguards the privacy and security of patient health information, applying to healthcare providers, insurers, and their partners.
- Difference between 27000 and PCI DSS, HIPAA ?

Why is FIM Important?

3. Forensics: Provides historical records of file changes.

Example Scenario:

« Malware Modifying System Files »

- A **rootkit** replaces **winlogon.exe** with a malicious version.

winlogon.exe ?

winlogon.exe:

1. Authentication management (authentication, biometrics, and smart cards)
2. Security and monitoring (detects user inactivity and can lock the screen)

Although winlogon.exe is a legitimate Windows process, **some malware uses a similar name** (winlogon.exe placed in the wrong directory) to hide its activity.

Rootkit ?

A rootkit is an advanced type of malware designed to hide deeply within the system and provide stealth access to an attacker.

The rootkit installs itself in a hidden folder (`C:\Users\Public\winlogon.exe` instead of `C:\Windows\System32\`).

Example Scenario:

« Malware Modifying System Files »

What is the role of FIM in detecting a rootkit that replaces winlogon.exe with a malicious version?

FIM detects the change in the file's hash and alerts the administrator.

Example Scenario 2: Unauthorized Configuration Changes

An attacker modifies **/etc/passwd** (user, permission) on Linux to add a backdoor account.

```
username:x:1001:1001:User Name,,,:/home/username  
:/bin/bashbackdoor:x:0:0:
```

```
backdoor:x:0:0:Backdoor User,,,:/root:/bin/bash
```

Example Scenario 2: Unauthorized Configuration Changes

1. FIM detects unauthorized **changes** in file content and permissions.
2. Prevents privilege escalation attacks.

Hash functions

A hash function (e.g., MD5, SHA1, SHA-256) generates a unique fixed-size string (hash) for a file's content. Even a small change in the file results in a completely different hash.

Hash functions

MD5: Fast but vulnerable to collision attacks (two different files producing the same hash).

- A software company releases an update (file A) and provides its MD5 hash as a way for users to verify that the update is legitimate.
- An attacker creates a malicious version of the update (file B) but manipulates it so that B has the same MD5 hash as A.
- When users download the update, they check the MD5 hash, see that it matches the expected value, and assume the file is safe.

Hash functions

PowerShell (as admin):

*Get - File Hash
"C:\Users\PC\Desktop\Securite_Informatique\Semestre2DetectionIntrusion\hash\file1.txt" -
Algorithm MD5*

Hash functions

SHA-1: More secure than MD5 but also susceptible to collisions.

SHA-256: Currently the most secure and widely used for FIM.

Limitations of Hashing

False Positives: Legitimate changes (e.g., updates, patches) can trigger alerts.

Advanced Considerations:

Real-Time Hashing: Advantages and limitations ?

Some FIM tools compute hashes in real-time, while others do it periodically. Real-time hashing is more resource-intensive but provides immediate detection.

Tamper-Proof Baselines: are the hash baseline safe ?

The original hashes (baselines) must be stored securely to prevent attackers from modifying them.

Comparison of FIM Tools

1. Samhain
2. Tripwire
3. OSSEC
4. Wazuh

Critère	Samhain	Tripwire	OSSEC	Wazuh
Type	HIDS (intégrité, rootkits)	Surveillance fichiers	HIDS (logs, intrusions)	HIDS + SIEM (logs, vulnérabilités)
Open Source	Oui	Oui	Oui	Oui
Fonctions	Intégrité, rootkits	Intégrité fichiers	Analyse logs, détection	Logs, vulnérabilités, SIEM
OS supportés	Linux, Unix, Windows (partiel)	Linux, Unix, Windows	Linux, Unix, Windows, macOS	Multi-OS + Cloud
Centralisation	Oui	Non	Oui	Oui
Interface	CLI	CLI	CLI	Dashboard (Kibana)
Scalabilité	Petit env.	Petit env.	Moyen env.	Grands env.
Communauté	Modeste	Active	Active	Très active + support commercial

Use Case: FIM with Wazuh

Environement:

1. Server (Lubuntu)
 - a. *QWERTY to AZERTY?*
 - b. *Copy/Paste (Alternative)*
2. Agent (Windows, Metasploitable 3 (not 2))
3. Installation (Classic or Docker)
4. *Dashboard*
5. *Agent: Installation and configuration*

Recap

1. Why is FIM important?
(Prevention of persistence, compliance, forensics)
2. Rootkits: How do they hide, and where?
3. MD5 vs. SHA-1 vs. SHA-256: Key differences
4. FIM Tools: Overview
5. Hands-on Lab 1: Wazuh installation & FIM use case

2. Comparison with Copies

FIM compares current files with a secure baseline copy. It Helps to identify exact changes and , allowing quick remediation.

Challenges ?

Storage overhead & baseline integrity.

3. Monitoring File Attributes

Step 1: Initial Baseline Creation

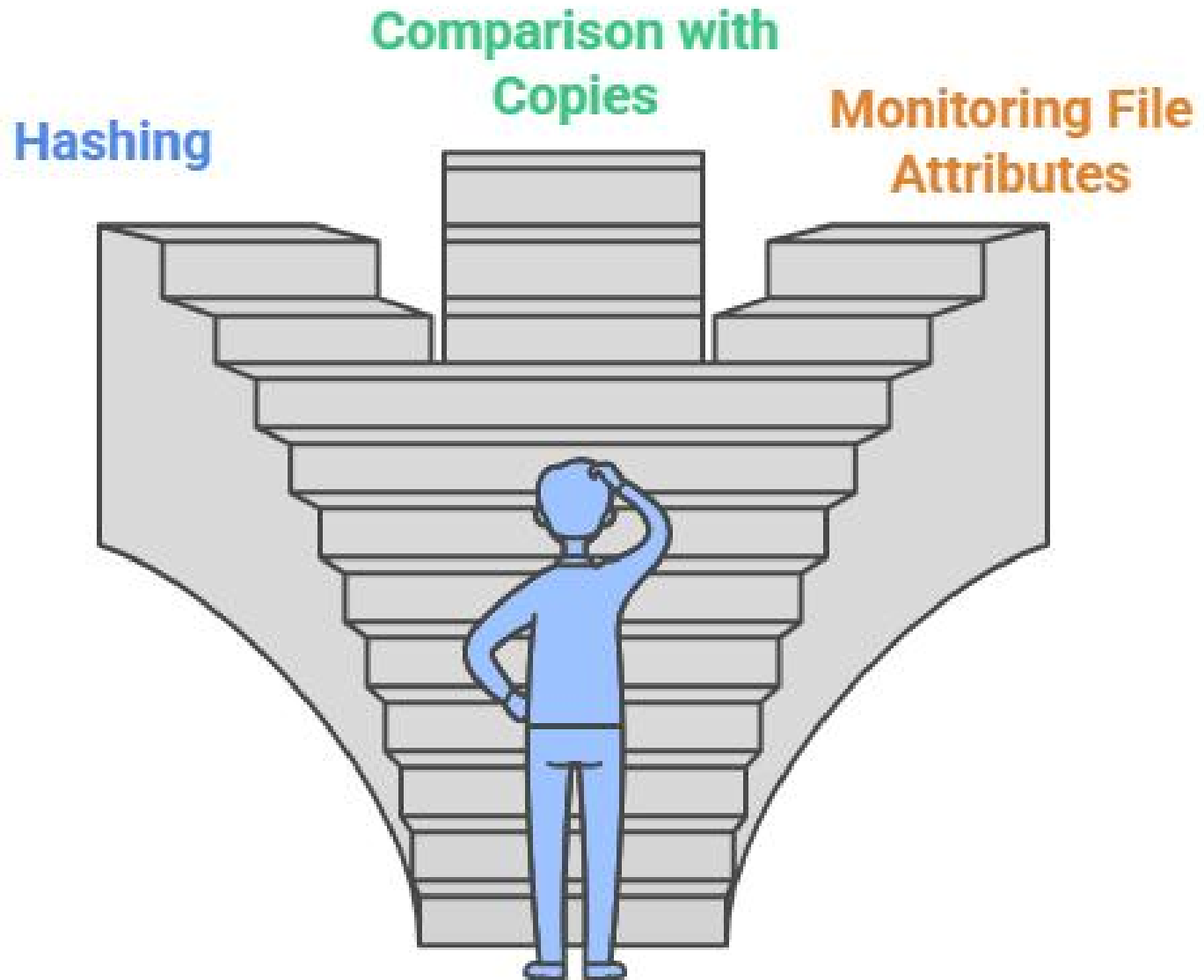
- The FIM tool scans files and directories to record key attributes:
 - **Permissions** (who can read/write/execute)
 - **Ownership** (which user/group owns the file)
 - **Size & Timestamps** (modification, access, and creation times)

3. Monitoring File Attributes

Step 2: Continuous Monitoring & Comparison

- The system periodically rescans files and **compares** them to the stored baseline.
- Changes (e.g., permission modifications, file replacements, or timestamp tampering) trigger **alerts**.

Which FIM method should be implemented?



3. Monitoring File Attributes

Which One to Choose?

1. For best security:

Combine **hashing + monitoring file attributes**.

2. For backup integrity:

Use **comparison with copies** but ensure proper security for stored backups.

3. For fast detection:

Use **monitoring file attributes** with real-time event listeners.

Does a HIDS exclusively perform File Integrity Monitoring (FIM)?

Core Functions of HIDS

1. File Integrity Monitoring (FIM)
2. Vulnerability Detection – Identifying Known Vulnerabilities

Core Functions of HIDS

How Does HIDS Detect Vulnerabilities?

1. Version Comparison:

Compares installed software versions against known vulnerable versions in databases like CVE (Common Vulnerabilities and Exposures) , NVD, or OSVDB.

<https://www.cvedetails.com/>

Hands-on Lab 2: Wazuh – Detecting Vulnerabilities

Introduction to Memory Safety Bugs

What is Memory Safety?

- Ensuring that a program accesses memory safely, avoiding corruption and crashes.

Why Does It Matter?

- Memory errors can lead to security vulnerabilities, crashes, and unpredictable behavior.

Common Memory Safety Issues

Buffer Overflows:

- Writing outside allocated memory boundaries.

Use-After-Free:

- Accessing memory after it has been deallocated.

How an Attacker Can Exploit This Vulnerability?

1. The **attacker** develops a **malicious web page** that contains JavaScript or WebAssembly code **that forces the browser** to process incorrect data, leading to memory corruption.
2. The user visits the malicious page
3. Execution of arbitrary code

Can you check if there are any
detected vulnerabilities on your agents?
If so, what are the most critical ones ?

Core Functions of HIDS

1. File Integrity Monitoring (FIM)
2. Vulnerability Detection – Identifying Known Vulnerabilities
3. Log Monitoring and Analysis

Why monitor login attempts in logs?
What types of attacks can be detected
through these logs?

Core Functions of HIDS

Log Monitoring and Analysis

- Function: Analyzes system, application, and security **logs** for suspicious activity.

Example:

Brute-force attack detection – Multiple failed login attempts on an SSH server (e.g., /var/log/auth.log in Linux) indicate a brute-force attack. HIDS identifies this pattern and alerts the administrator.

Hands-on Lab 3: Wazuh – Log Monitoring and Analysis

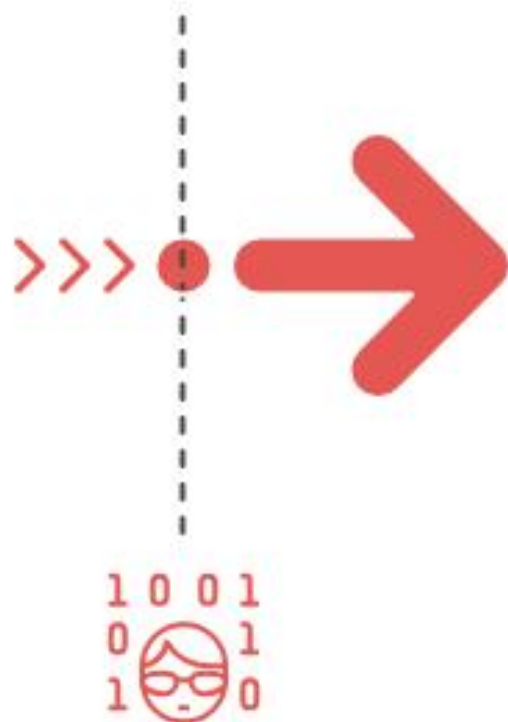
What configuration do we need for this lab to effectively monitor and analyze logs?

(Think about the victim machine, the attacker, and the monitoring system.)

Wazuh Log Monitoring and Analysis Lab Sequence

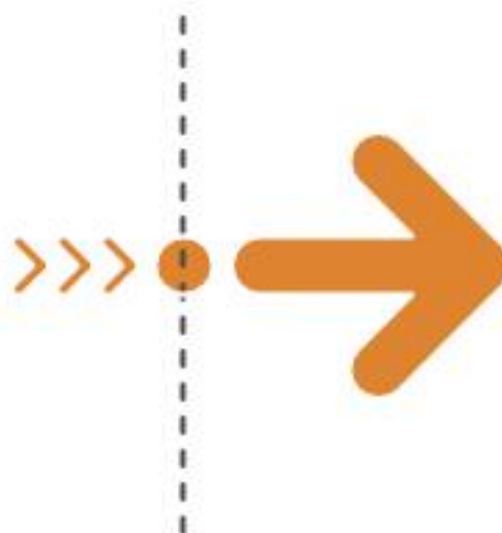
Kali Linux as Attacker

Initiates brute force attack on Windows system



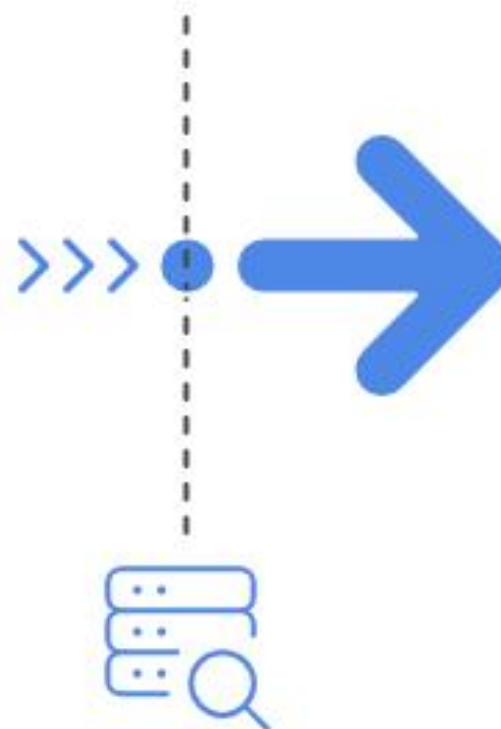
Windows as Victim

Receives and logs attack attempts



Wazuh Server Analysis

Detects and analyzes logs from Windows



Before setting up log monitoring, what should we check to ensure that a brute force attack can be performed on the victim machine?

After Scanning

- 135/tcp (MSRPC)
- 139/tcp (NetBIOS-SSN)
- 445/tcp (Microsoft-DS)
- 5357/tcp (WSDAPI)

135/tcp (MSRPC - Microsoft Remote Procedure Call)

- **MSRPC** itself **is not typically brute-forced directly**. However, it can be used to enumerate services or exploit vulnerabilities that might lead to credential theft.
- **Verdict: Not directly brute-forceable.**

139/tcp (NetBIOS-SSN - NetBIOS Session Service)

- **NetBIOS** can be used to enumerate shared resources and user accounts. **While not directly brute-forceable**, it can aid in attacks against SMB.
- Verdict: Not directly brute-forceable, but useful for enumeration.

445/tcp (Microsoft-DS - SMB - Server Message Block)

- **SMB** is commonly targeted for brute-force attacks, especially if authentication is required (e.g., Windows shares, RDP over SMB).
- Attackers often use tools like **Hydra**, **Medusa**, or **CrackMapExec** to brute-force SMB credentials.
- Verdict: Yes, can be brute-forced if password authentication is enabled.

Script to apply Brute force:

```
medusa -h 192.168.1.35 -U  
/home/kali/Desktop/username.txt -P  
/home/kali/Desktop/pass.txt -M smbnt
```

Do we need to configure the ossec.conf agent file to detect failed or successful logins?

In Wazuh's configuration, the `eventchannel` keyword in `<log_format>` means that the Wazuh agent will collect logs directly from the Windows Event Log via the event channel.

Try applying a brute-force attack on the victim machines and check if it is detected on the Wazuh server.